

SCORING ENGINE

HORIZON GRID

Threat Scoring

Version: 0.2.5

Documentation prepared: 2026-08-23

PREPARED FOR EVALUATION

Table of Contents

HORIZON GRID Threat Scoring — How the Number Is Actually Computed	3
---	---

HORIZON GRID Threat Scoring — How the Number Is Actually Computed

Why this document exists

Every investigation in HORIZON GRID ends with a threat score from 0-100, a confidence percentage, a malicious-probability percentage, and a severity band (none/low/medium/high/critical). This document explains exactly how those four numbers are produced — not an approximation, the real formula, taken directly from `app/scoring/engine.py` (`SCORING_ENGINE_VERSION = "1.0"`), the module that computes them.

The single most important fact about this engine: it is deterministic, not AI-generated. The score is computed from real, structured evidence — provider verdicts and correlation-graph relationships — using fixed weights and formulas, before the AI is ever called. The AI is handed the finished number as a given fact and asked only to explain it in prose. It cannot invent a different number, and if it tries, the platform overwrites its output with the real one and re-validates the whole assessment against that real number before anything is saved. This is covered in full in the AI Guide; this document is about the number itself.

Threat score ≠ confidence — read this before anything else

A HORIZON GRID assessment might show:

```
Threat Score: 87 / 100 (severity: critical)
Confidence: 54%
```

These are two different questions with two different answers:

- **Threat score** (`overall_risk_score` , `malicious_probability`) asks: *how malicious does the evidence look?* An 87 means the evidence, taken at face value, points strongly toward malicious.
- **Confidence** (`confidence_score`) asks: *how much should you trust that number?* A 54% means the evidence behind that 87 is thinner or more conflicted than you'd want before acting on it alone — for example, a single uncorroborated source, or two sources that disagree with each other.

A high score with low confidence is a real, correct, and useful combination — it means "this looks bad, but verify it before treating it as certain," not "the platform doesn't know what it's doing." A future analyst should always read both numbers together, never the score alone.

The two inputs that build the score

The 0-100 malicious-evidence budget is split across two additive components that sum to 100 points:

Component	Max points	Source
Provider-verdict consensus	65	Every provider that returned a real result and reported a verdict/reputation
Correlation-graph evidence	35	Malware/threat-actor/campaign associations, MITRE technique usage, CVE exploitation discovered by the correlation engine

These two components, added together, produce `malicious_probability` — deliberately a pure reputation/relationship signal, not inflated by anything else (see the Security Assessment section below for why that separation matters).

Component 1: provider-verdict consensus (65 points)

Each provider that returned data casts a vote between 0.0 (clean) and 1.0 (malicious). Most providers report a simple `malicious` / `suspicious` / `clean` verdict, which maps to 1.0/0.55/0.0. A provider like VirusTotal that reports a real multi-engine detection ratio (e.g. 48 of 72 engines flagged it) uses that ratio directly instead — a graduated signal is always preferred over a categorical one when it's available.

A provider that returns no decodable verdict at all (missing, or an unrecognized string) casts **no vote** — it is excluded from the calculation entirely, never coerced into "clean." Treating silence as innocence would manufacture confidence no provider actually offered.

Corroboration matters, and is enforced mathematically, not just described. A single provider flagging something malicious, with no other provider agreeing *or* disagreeing, is capped at 40% of this component's maximum strength. It takes 5 independent, agreeing providers to reach full strength:

Agreeing providers	Strength multiplier
1	40%
2	55%
3	70%
4	85%
5+	100%

This exists because a plain average of votes does not have this property — one provider voting 100% malicious would average to the same 100% as five providers all voting 100% malicious, which is not an honest reflection of how much corroboration actually exists. The multiplier is applied on top of the mean vote, not folded into it.

Conflicting verdicts are not quietly averaged away. If one provider says malicious and another says clean, `malicious_probability` reflects the honest mean of what was actually said — a genuine split IS uncertain, and reporting it as certain would be the error. But the *confidence* component's provider term is separately multiplied by `(1 - agreement_spread)`, where `agreement_spread` is the distance between the most- and least-malicious vote received. Perfect agreement leaves confidence untouched; a full 1.0-vs-0.0 split drives that term to zero. This is the concrete mechanism behind a case like "high score, low confidence" — the disagreement itself is what collapses the confidence number, on purpose.

Component 2: correlation-graph evidence (35 points)

The correlation engine (`app/correlation/engine.py`) builds a graph of relationships between the investigated indicator and things providers associate it with — malware families, threat actors, campaigns, MITRE ATT&CK techniques, exploited CVEs. Only relationships that plausibly indicate malice by themselves qualify for scoring: `associated_with` , `attributed_to` , `part_of_campaign` , `exploits` ,

`uses_technique` . Purely infrastructural relationships (an IP resolving to a domain, a domain sharing a TLS certificate) do **not** qualify — resolving to something is not, by itself, evidence of anything malicious.

Each qualifying edge carries a confidence value; the sum of qualifying edge confidences, scaled against a saturation point of 2.0 (roughly equivalent to two fully-corroborated malware-family associations), produces this component's raw strength.

A real vulnerability was found and fixed here during this project's own red-team testing, and it is worth explaining because it shapes how this component behaves today. Several providers (AlienVault OTX, ThreatFox, MalwareBazaar) build these relationships from free-text fields in community-submitted threat intelligence — meaning a single free, unprivileged account on one of those services could previously publish a submission listing several distinct (but fabricated) malware-family names about *any* indicator, generating several separate graph edges from one source with zero real corroboration, and push an innocent indicator's score into the "high" severity band. This was reproduced numerically during adversarial testing and fixed by applying the *same* corroboration-multiplier logic used for provider votes to correlation edges as well — keyed on the number of distinct providers that actually asserted a qualifying relationship, not the number of edges. A flood of fabricated claims from one source is now capped at the same 40% ceiling a lone provider vote receives; genuine agreement from two or more independent providers scales back up toward full strength, exactly as before. This closed the gap without weakening real, corroborated findings.

Security Assessment findings: a floor, not an additive term

If the Security Assessment Toolkit (active scanning — port/TLS/DNS/HTTP checks) has ever run against this indicator, its most severe finding acts as a **floor** on `overall_risk_score` and `confidence_score` only:

Finding severity	Risk floor	Confidence floor
Critical	70	60
High	45	45
Medium	20	30
Low	5	15
Info	0	0

This is deliberately a floor (`overall_risk_score = max(reputation_score, sa_floor)`), not an addition, and it is deliberately **excluded from** `malicious_probability` . The reasoning: a direct technical observation this platform made itself right now (an open critical vulnerability the scanner actually touched) is trustworthy without needing cross-provider corroboration the way a third-party reputation opinion does — but a vulnerability finding ("this target is dangerous to leave reachable") is a fundamentally different claim than "this indicator is a confirmed malicious actor." An unpatched, exposed service on an otherwise-unknown IP does not by itself prove that IP is malicious — but it absolutely should raise the overall risk picture regardless of what any reputation feed says. Keeping the two numbers separate means `malicious_probability` always means exactly what it says, and a severe technical exposure correctly cannot, by itself, force a "malicious" verdict — but it can, correctly, still force a "high" or "critical" overall risk score.

Severity bands

`overall_risk_score` is mapped to a severity label using fixed, documented thresholds (a starting judgment call, not a statistically calibrated model — there is no labeled dataset this platform trains against):

Score	Severity
≥ 80	Critical
≥ 55	High
≥ 30	Medium
≥ 10	Low
< 10	None

Versioning and auditability

Every persisted assessment records `scoring_engine_version` (currently `"1.0"`) and a full `scoring_breakdown` — every intermediate number that went into the final score (mean provider vote, corroboration factor, correlation fraction, security-assessment floor, and so on) — alongside the final numbers. This was itself a real gap found and fixed during this project: the engine always computed this breakdown, but an early version of the integration discarded it before saving. It is now persisted on every assessment, so a past score can always be explained and traced back to exactly which version of the weighting scheme produced it, rather than requiring anyone to trust the number on faith.

Worked example

A real live investigation during this project's own testing, with AlienVault OTX as the only provider casting a vote (malicious, lone provider — 40% corroboration strength) plus one corroborated malware-family correlation edge:

```
voting_provider_count: 1          mean_provider_vote: 1.0
provider_corroboration_factor: 0.40  -> provider_component: 26.0
correlation_qualifying_fraction: 0.575  -> correlation_component: 20.1
overall_risk_score / malicious_probability: 46.1  (severity: medium)
confidence_score: 28.4  (pulled down by the single-source corroboration cap)
```

Read together: the evidence leans toward malicious (46.1, medium), but the confidence (28.4%) correctly signals this rests on one uncorroborated source — exactly the kind of result an analyst should verify further before acting on, and exactly the distinction this document opened with.